

Laporan Blocker Implementasi Push Notification Mobile TradePilot.id

Tanggal audit: 14 September 2026 **Status:** Belum siap dinyatakan berhasil secara end-to-end **Backend:** /Users/newsmaker23/flutterproject/major/Trade-Pilot - branch prodd-v2, commit 403edd4 **Mobile:** /Users/newsmaker23/flutterproject/major/tradepilotapp - branch native-push-notifications-1.0.2, basis commit b740129 beserta perubahan push notification yang belum di-commit **Lampiran:** Lampiran A memuat kontrak Sign in with Apple - **topik terpisah** yang tidak berkaitan dengan blocker push notification

1. Ringkasan eksekutif

Implementasi push notification **sudah tersedia pada sisi aplikasi mobile**, meliputi inisialisasi Firebase, permintaan izin, pengambilan dan registrasi token FCM, penanganan token refresh, notifikasi foreground, background handler, deep link/action, serta tombol test push.

Namun, push notification **belum dapat dinyatakan berfungsi** karena jalur pengiriman dari backend menuju Firebase Cloud Messaging (FCM) belum terbukti berhasil. Pengujian aktual menunjukkan:

1. Perangkat berhasil didaftarkan ke backend.
2. Endpoint POST /api/native-push/test menerima permintaan.
3. Backend melaporkan sejumlah perangkat sebagai delivered.
4. Perangkat yang sedang diuji tidak menerima pesan FCM dalam 15 detik.

Penyebab teknis paling kuat adalah konfigurasi runtime Firebase di backend - FIREBASE_PROJECT_ID dan Application Default Credentials (ADC) - belum terverifikasi pada environment production. Kode backend akan **diam-diam menghentikan pengiriman** jika project ID tidak tersedia. Selain itu, endpoint test saat ini melaporkan jumlah token yang ditargetkan, bukan jumlah pesan yang benar-benar diterima atau diterima oleh FCM. Akibatnya, respons sukses dari endpoint dapat menjadi **false positive**.

Kesimpulan utama: blocker saat ini berada pada jalur delivery backend ke FCM, bukan pada UI notifikasi mobile. Mobile sudah cukup siap untuk pengujian end-to-end, tetapi fitur belum boleh dianggap production-ready sampai backend membuktikan FCM menerima pesan dan perangkat Android/iOS benar-benar menerimanya.

2. Ruang lingkup audit

Audit mencakup:

- konfigurasi Firebase Android dan iOS pada aplikasi Flutter;
- alur izin, token, registrasi, unregister, token refresh, dan penerimaan pesan;
- kontrak endpoint native push pada API client dan backend;
- implementasi FCM HTTP v1 pada backend;
- dokumentasi deployment backend;
- test backend yang berhubungan dengan native push;
- hasil uji manual tombol test push pada aplikasi.

Audit ini **tidak dapat membaca Replit Publishing Secrets, IAM Google Cloud, Firebase Console, atau konfigurasi APNs production**. Karena itu, secret/credential production dinyatakan *belum terverifikasi*, bukan dipastikan tidak ada.

Sign in with Apple **berada di luar ruang lingkup audit ini**. Kontraknya didokumentasikan pada Lampiran A karena tim penerimanya sama, bukan karena ada hubungan teknis dengan push notification.

3. Alur yang diharapkan dan kondisi saat ini

Mobile meminta izin notifikasi	BERHASIL/TERSEDIA
Mobile memperoleh token FCM	BERHASIL/TERSEDIA
POST /api/native-push/register	BERHASIL
Token tersimpan di native_push_devices	TERINDIKASI BERHASIL
POST /api/native-push/test	DITERIMA BACKEND
Backend memperoleh OAuth token melalui ADC	BELUM TERVERIFIKASI
Backend mengirim ke FCM HTTP v1	GAGAL/TAK TERBUKTI
FCM meneruskan ke Android atau APNs	TAK TERBUKTI
Perangkat menampilkan notifikasi	GAGAL PADA UJI AKTUAL

4. Temuan dan penyebab utama

P0-1 - Konfigurasi FCM backend belum terjamin pada deployment

Backend hanya mengaktifkan native push apabila FIREBASE_PROJECT_ID tersedia:

```
const projectId = process.env["FIREBASE_PROJECT_ID"] || "";
const nativePushConfigured = Boolean(projectId);

if (!nativePushConfigured) {
  logger.warn("FIREBASE_PROJECT_ID is missing...");
}
```

Ketika variabel tersebut kosong, sendNativePushToUser() langsung berhenti tanpa error:

```
if (!nativePushConfigured) return;
```

File .replit tidak mendefinisikan FIREBASE_PROJECT_ID. Checklist utama replit.md untuk Publishing Secrets juga hanya menyebut OPENAI_API_KEY dan VAPID_PRIVATE_KEY, bukan konfigurasi native FCM. Dokumen lain, STORE_RELEASE_WEB_BACKEND_CHECKLIST.md, memang menyebut kebutuhan berikut:

- FIREBASE_PROJECT_ID=trade-pilot-newsmaker23;
- Application Default Credentials untuk service account;
- APNs Authentication Key untuk iOS.

Ini menunjukkan kebutuhan konfigurasi sudah diketahui, tetapi belum konsisten dijadikan gate pada deployment utama. Repository tidak dapat membuktikan apakah nilai tersebut benar-benar telah dipasang di production.

Dampak: registrasi perangkat dan endpoint test tetap dapat bekerja, tetapi tidak ada pesan yang dikirim ke FCM.

P0-2 - Endpoint test menghasilkan false positive

Endpoint POST /api/native-push/test menghitung token aktif di database, menjalankan fungsi send, lalu mengembalikan:

```
{ "delivered": 4 }
```

Nilai delivered saat ini sebenarnya adalah **jumlah row perangkat aktif yang ditargetkan**, bukan jumlah pesan yang berhasil diterima FCM atau perangkat.

Test backend bahkan mendokumentasikan perilaku ini: ketika `FIREBASE_PROJECT_ID` tidak diset sehingga FCM menjadi no-op, endpoint tetap diharapkan mengembalikan `delivered = 1`.

Dampak: mobile dapat menampilkan “test requested for 4 registered devices” meskipun tidak satu pun pesan dikirim. Status tersebut menyesatkan proses troubleshooting dan tidak bisa dipakai sebagai bukti bahwa push bekerja.

P0-3 - Kegagalan FCM ditelan dan tidak dikembalikan ke caller

Fungsi pengiriman menangkap error HTTP dari FCM, menulis log, lalu mengembalikan void. Endpoint test tidak menerima ringkasan berhasil/gagal. Selain itu, `auth.getClient()` dipanggil sebelum blok try, sehingga kegagalan memperoleh ADC dapat keluar sebagai error yang tidak dilaporkan secara terstruktur.

Dampak: mobile tidak memperoleh alasan kegagalan yang bisa ditindaklanjuti, misalnya:

- ADC/service account tidak ditemukan;
- service account tidak memiliki izin FCM;
- Firebase project salah;
- Firebase Cloud Messaging API belum aktif;
- token berasal dari project Firebase berbeda;
- APNs belum dikonfigurasi untuk iOS.

P0-4 - Uji aktual membuktikan request diterima, tetapi pesan tidak tiba

Mobile sekarang melakukan langkah berikut saat tombol test ditekan:

1. memastikan notifikasi diaktifkan dan izin OS diberikan;
2. mengambil token FCM terkini;
3. memaksa registrasi ulang token tersebut;
4. memanggil endpoint test;
5. menunggu event FCM aktual selama maksimal 15 detik.

Hasil uji:

“The server accepted the test, but this device did not receive an FCM message within 15 seconds. Backend Firebase credentials and project configuration need to be checked.”

Hasil ini mempersempit masalah: request mobile, autentikasi endpoint, dan registrasi token dapat berjalan, tetapi delivery dari backend ke perangkat gagal atau belum dikonfigurasi.

5. Kesiapan sisi mobile

Area	Status	Bukti/keterangan
Firebase bootstrap	Siap	<code>Firebase.initializeApp()</code> dijalankan saat startup dan background handler terdaftar.
Firebase Android	Siap secara kode	<code>google-services.json</code> memakai project <code>trade-pilot-newsmaker23</code> dan package <code>id.tradepilot.app</code> .
Firebase iOS	Siap secara kode	<code>GoogleService-Info.plist</code> memakai project yang sama dan bundle <code>id.tradepilot.app</code> .
Izin Android	Siap	<code>POST_NOTIFICATIONS</code> tersedia pada manifest.

Area	Status	Bukti/keterangan
Channel Android	Siap	Channel <code>trade_pilot_alerts</code> dibuat dan dijadikan default FCM channel.
Capability iOS	Parsial	Entitlement <code>aps-environment</code> dan background mode tersedia; delivery tetap harus diuji pada perangkat fisik serta memerlukan APNs key di Firebase.
Token FCM	Siap	Token diambil, diregistrasikan, dan disinkronkan saat refresh.
Registrasi backend	Siap	Menggunakan <code>POST /native-push/register</code> .
Unregister	Siap	Menggunakan <code>DELETE /native-push/unregister</code> .
Foreground notification	Siap	Pesan foreground diteruskan ke local notification dengan importance tinggi.
Background/terminated action	Siap secara kode	Initial message dan <code>onMessageOpenedApp</code> ditangani melalui action allowlist.
Test push	Siap untuk diagnosis	Mobile menunggu event FCM aktual, tidak lagi mempercayai angka <code>delivered</code> backend saja.

Catatan: build iOS Simulator hanya memvalidasi kompilasi. Ia **tidak membuktikan APNs production**. Pengujian iOS final wajib menggunakan perangkat fisik.

6. Masalah lanjutan yang perlu diperbaiki

Temuan berikut bukan penyebab tunggal test saat ini gagal, tetapi berpotensi membuat push tidak stabil atau tidak sesuai preferensi pengguna setelah blocker utama selesai.

P0-5 - Token dapat terhapus karena semua HTTP 400/404 dianggap invalid

Backend menghapus token pada setiap respons FCM status 400 atau 404. Tidak semua 400/404 berarti token sudah tidak terdaftar; kesalahan project, payload, atau konfigurasi juga dapat menghasilkan error serupa.

Perbaikan: hapus token hanya bila detail error FCM secara eksplisit menyatakan `UNREGISTERED`. Untuk `INVALID_ARGUMENT`, pastikan kesalahan memang berada pada token sebelum menghapusnya.

P1-1 - Token lama tidak dipangkas berdasarkan `lastSeenAt`

Satu akun dapat mempunyai beberapa row token lama. Angka “4 perangkat terdaftar” belum tentu berarti empat perangkat aktif. Saat token Firebase berubah, token baru didaftarkan tetapi token lama bergantung pada kegagalan send untuk dibersihkan.

Perbaikan: simpan installation ID non-rahasia per instalasi atau lakukan pruning token yang lama/tidak pernah terlihat lagi dengan retensi yang disepakati.

P1-2 - Deteksi push untuk auto-arm price alert hanya memeriksa Web Push

`userHasPushSubscription()` membaca tabel `pushSubscriptions` (Web Push), bukan `native_push_devices`. Pengguna mobile yang hanya mempunyai native push dapat dianggap tidak mempunyai push sehingga alert analisis tidak otomatis diaktifkan.

Perbaikan: cek kedua channel yang enabled, atau buat fungsi gabungan `userHasAnyPushChannel()`.

P1-3 - Preferensi kategori belum sepenuhnya dipakai pada producer

Field `pushAnalysisCompleted` dan `pushTpSlHit` tersedia pada preference API, tetapi penggunaan field tersebut tidak ditemukan pada jalur producer terkait. Master switch `nativePushEnabled` memang diperiksa, tetapi granular preference berisiko belum dihormati.

Perbaikan: sebelum setiap producer mengirim, periksa preference kategori yang sesuai dan tambahkan test positif/negatif.

P1-4 - Quiet hours mengabaikan menit

Input menerima format HH:MM, tetapi evaluasi menggunakan jam saja. Contoh 22:30 berperilaku seperti 22:00.

Perbaikan: bandingkan menit sejak tengah malam, gunakan timezone pengguna, dan test window yang melewati tengah malam.

P1-5 - Pengiriman ke banyak perangkat dilakukan berurutan

Setiap device mempunyai timeout 8 detik dan dikirim secara serial. Beberapa token lambat dapat membuat request test atau producer tertahan lama.

Perbaikan: gunakan concurrency terbatas atau `Promise.allSettled()` dan kembalikan ringkasan hasil.

7. Perbaikan wajib di backend

7.1 Konfigurasi production

- Set `FIREBASE_PROJECT_ID=trade-pilot-newsmaker23` pada **Publishing/Runtime Secrets**, bukan di Flutter.
- Pastikan backend mempunyai ADC yang valid pada runtime.
- Gunakan service account khusus server dengan izin minimum untuk mengirim FCM, misalnya izin `firebasecloudmessaging.messages.create` melalui role yang sesuai.
- Pastikan Firebase Cloud Messaging API aktif pada project yang benar.
- Pastikan token mobile dan service account berasal/berwenang pada project Firebase yang sama.
- Upload APNs Authentication Key .p8, Key ID, dan Team ID pada Firebase Console untuk aplikasi iOS.
- Jangan menyimpan service-account JSON di repository, Flutter assets, APK/IPA, log, atau dokumentasi publik.

7.2 Perbaiki kontrak hasil pengiriman

Rekomendasi respons endpoint test:

```
{
  "configured": true,
  "targeted": 1,
  "accepted": 1,
  "failed": 0,
  "invalidTokensRemoved": 0
}
```

Aturan minimum:

- jika FCM tidak dikonfigurasi, kembalikan 503 Service Unavailable dengan kode stabil seperti `NATIVE_PUSH_NOT_CONFIGURED`;
- `targeted` = jumlah token yang dipilih dari database;
- `accepted` = jumlah request yang diterima FCM dan menghasilkan message name;
- `failed` = jumlah request yang ditolak atau error;
- jangan menyebut `delivered` karena backend tidak mempunyai delivery receipt perangkat;
- simpan error internal yang aman di log, tetapi jangan mengirim token penuh atau credential ke client/log.

7.3 Perbaiki fungsi pengiriman

- Letakkan proses memperoleh client ADC dan request FCM dalam error handling yang sama.
- Kembalikan hasil terstruktur per device atau agregat.
- Bedakan error konfigurasi, auth/IAM, payload, rate limit, timeout, dan token unregistered.
- Hapus token hanya pada sinyal FCM UNREGISTERED yang valid.
- Tambahkan correlation/request ID agar log endpoint dapat ditelusuri tanpa mencatat token penuh.
- Gunakan retry terbatas hanya untuk error transient (429/5xx) dengan backoff; jangan retry error auth, payload, atau token invalid.

7.4 Perbaiki automated test

- Test kondisi FIREBASE_PROJECT_ID hilang menghasilkan failure yang jujur, bukan delivered > 0.
- Mock keberhasilan FCM dan pastikan accepted dihitung dari respons FCM.
- Mock ADC/IAM failure.
- Mock UNREGISTERED dan pastikan hanya token tersebut yang dihapus.
- Mock HTTP 400 akibat payload dan pastikan token tidak dihapus sembarangan.
- Test akun dengan beberapa device: sebagian sukses dan sebagian gagal.
- Test master switch dan preference kategori.

8. Tanggung jawab per tim

Pekerjaan	Mobil e	Backend/DevOp s	Firebase/Apple Admin
Konfigurasi Firebase SDK pada aplikasi	R	C	C
Permission, token lifecycle, foreground display	R	C	-
Endpoint register/unregister/test	C	R	-
FIREBASE_PROJECT_ID production	-	R	C
ADC/service account dan IAM	-	R	A/C
FCM API enablement	-	C	R
APNs key untuk iOS	C	C	R
Observability dan respons test yang akurat	C	R	-
Uji Android/iOS end-to-end	R	R	C

Keterangan: **R** = Responsible, **A** = Accountable, **C** = Consulted.

9. Urutan penyelesaian yang disarankan

1. Backend/DevOps memeriksa log startup production untuk warning FIREBASE_PROJECT_ID is missing.
2. Verifikasi FIREBASE_PROJECT_ID, ADC, IAM, dan FCM API pada runtime production.
3. Ubah endpoint test agar mengembalikan hasil FCM yang nyata dan 503 saat belum dikonfigurasi.
4. Jalankan test menggunakan **satu token Android terbaru** dan cocokkan request ID dengan log backend.
5. Setelah Android berhasil, konfigurasi APNs di Firebase dan test iOS pada perangkat fisik.
6. Perbaiki token cleanup, stale token handling, category preference, dan quiet hours.
7. Jalankan matriks regresi sebelum mengaktifkan fitur untuk semua pengguna.

10. Acceptance criteria

Push notification boleh dinyatakan siap apabila seluruh kondisi berikut terpenuhi:

- Endpoint test gagal secara eksplisit jika Firebase backend belum dikonfigurasi.
- Respons test membedakan token yang ditargetkan dan pesan yang diterima FCM.
- Satu perangkat Android fisik menerima test push pada foreground, background, dan terminated state.
- Satu perangkat iOS fisik menerima test push pada foreground, background, dan terminated state.
- Tap notification membuka tujuan yang benar melalui action allowlist.
- Token refresh tidak membuat user kehilangan push.
- Logout/unregister menghentikan push akun lama pada perangkat tersebut.
- Permission denied tidak menghasilkan klaim “push aktif”.
- `nativePushEnabled=false` menghentikan OS push tetapi in-app notification tetap tersedia sesuai desain.
- Preference kategori dan quiet hours dihormati.
- Token invalid dibersihkan tanpa menghapus token valid akibat salah konfigurasi.
- Log production tidak mengandung FCM token penuh, service-account key, access token, atau data sensitif pengguna.

11. Matriks uji minimum

Skenario	Ekspektasi
Android - app foreground	Event diterima dan local notification tampil.
Android - app background	OS notification tampil; tap membuka tujuan benar.
Android - app terminated	OS notification tampil; tap diproses melalui initial message.
iOS physical - tiga app state	Perilaku setara setelah APNs key valid.
Satu akun, dua device	Keduanya ditargetkan; hasil per device dapat diaudit.
Token lama/unregistered	Hanya token UNREGISTERED yang dihapus.
ADC tidak tersedia	Endpoint test mengembalikan failure terstruktur, bukan sukses.
FCM menolak payload	Token tidak otomatis dihapus; error tercatat aman.
Master switch off	Tidak ada native push.
Category switch off	Producer kategori terkait tidak mengirim.
Quiet hours 22:30-07:15	Menit dan timezone dihormati.
Rate limit test	Mobile menerima 429 dan menampilkan pesan yang sesuai.

12. Bukti kode utama

Backend

- `artifacts/api-server/src/lib/native-push.ts:25-39` - activation bergantung pada `FIREBASE_PROJECT_ID` dan `ADC`.
- `artifacts/api-server/src/lib/native-push.ts:85-111` - request FCM, error handling, dan penghapusan token pada semua 400/404.

- artifacts/api-server/src/lib/native-push.ts:121-146 - no-op jika tidak configured dan pengiriman device secara serial.
- artifacts/api-server/src/routes/native-push.ts:111-141 - endpoint test mengembalikan jumlah row sebagai delivered.
- artifacts/api-server/src/routes/__tests__/native-push.test.ts:253-266 - test menerima false positive ketika FCM no-op.
- .replit:89-102 dan replit.md:104-113 - native FCM tidak tercantum pada konfigurasi/checklist deployment utama.
- docs/STORE_RELEASE_WEB_BACKEND_CHECKLIST.md:265-278 - kebutuhan FCM/ADC/APNs didokumentasikan terpisah.
- artifacts/api-server/src/lib/price-alerts.ts:228-239 - deteksi push hanya melihat Web Push.
- artifacts/api-server/src/lib/notification-guards.ts:73-89 - quiet hours bekerja pada level jam.

Mobile

- lib/main.dart:41-50 - Firebase bootstrap dan background handler.
- lib/main.dart:78-82 - lifecycle NativePushService melalui provider.
- lib/services/native_push_service.dart:79-137 - messaging listeners, channel, token refresh, dan initial message.
- lib/services/native_push_service.dart:140-165 - permission dan enable flow.
- lib/services/native_push_service.dart:212-241 - APNs/FCM token sync.
- lib/services/native_push_service.dart:244-285 - force register, test endpoint, dan verifikasi receipt selama 15 detik.
- android/app/src/main/AndroidManifest.xml:1-52 - permission dan Android notification channel.
- ios/Runner/Runner.entitlements:5-6 - entitlement APNs development.

13. Keputusan akhir

Push notification **secara arsitektur sudah dapat didukung** oleh website/backend dan aplikasi mobile. Yang belum selesai adalah bukti dan keandalan delivery end-to-end.

Status saat ini:

- **Mobile implementation:** siap untuk integrasi dan pengujian end-to-end.
- **Backend API registration:** tersedia dan dapat diakses.
- **Backend FCM runtime:** belum terverifikasi dan paling mungkin menjadi blocker pengiriman.
- **Endpoint test:** belum dapat dipercaya sebagai bukti delivery.
- **Android production readiness:** tertahan sampai FCM accepted + device receipt terbukti.
- **iOS production readiness:** tertahan sampai FCM/ADC valid, APNs key terpasang, dan perangkat fisik lulus uji.

Dengan demikian, tindakan berikutnya bukan menambahkan Firebase credential ke aplikasi mobile. Tindakan yang benar adalah mengaktifkan dan memverifikasi credential server, memperbaiki observability/kontrak endpoint test, lalu menjalankan pengujian end-to-end pada perangkat fisik.

Lampiran A - Kontrak Sign in with Apple

Topik terpisah dari blocker push notification. Bagian ini tidak menjelaskan penyebab push gagal dan tidak bergantung padanya. Lampiran disatukan di dokumen ini semata agar tim backend punya satu berkas handoff mobile.

Status: mobile **sudah selesai**, backend **belum punya endpoint**. **Sifat:** blocker rilis App Store, bukan blocker fungsional.

A.1 Mengapa ini wajib

App Store Review Guideline 4.8 mewajibkan aplikasi yang menawarkan login pihak ketiga menyediakan Sign in with Apple pada platform Apple. TradePilot mobile sudah menawarkan "Lanjutkan dengan Google", sehingga build iOS **akan ditolak review** tanpa Sign in with Apple.

Karena itu pekerjaan ini berdiri sendiri: push notification boleh tetap tertahan, tetapi tanpa endpoint Apple, aplikasi iOS tidak bisa masuk App Store sama sekali.

A.2 Yang sudah selesai di mobile

Bagian	Berkas	Keterangan
Dependency	pubspec.yaml:53-54	sign_in_with_apple: ^7.0.1, crypto: ^3.0.7
Entitlement	ios/Runner/Runner.entitlements:7-10	com.apple.developer.applesignin = Default
Ambil credential	lib/providers/auth_provider.dart:320-353	Guard iOS, cek ketersediaan, buat nonce, minta scope email + fullName
Tukar sesi	lib/providers/auth_provider.dart:261-306	POST /auth/apple/native, deserialisasi AuthResponse
Allowlist tanpa bearer	lib/providers/auth_provider.dart:99	/auth/apple/native tidak menyertakan Authorization
Tombol	lib/screens/auth/login_screen.dart:245-267	Hanya dirender saat TargetPlatform.iOS
Batal vs gagal	lib/providers/auth_provider.dart:797-799	Batal oleh user tidak memunculkan pesan error
Peta error	lib/providers/auth_provider.dart:821-845	Lihat A.6

Mobile memakai **dependency injection** (AppleCredentialProvider), jadi alur ini dapat diuji tanpa perangkat Apple.

A.3 Kontrak endpoint yang diasumsikan

Mobile sudah memanggil endpoint berikut. **Backend tinggal menyesuaikan dengan bentuk ini**; jika backend memilih bentuk lain, mobile perlu diubah dan harus dikabarkan lebih dulu.

```
POST /auth/apple/native
Content-Type: application/json
(tanpa Authorization header)
```

Request body

Field	Tipe	Wajib	Keterangan
identityToken	string	ya	JWT dari Apple. Berisi klaim sub, email, nonce.

Field	Tipe	Wajib	Keterangan
authorizationCode	string	ya	Kode sekali pakai, umurnya 5 menit. Lihat A.5.
nonce	string	ya	Nonce mentah . Lihat A.4 - ini bagian paling mudah salah.
givenName	string	tidak	Hanya dikirim pada otorisasi pertama. Sudah di-trim mobile.
familyName	string	tidak	Sama seperti di atas.

Response 200 - sama persis dengan /auth/google/native, yaitu skema AuthResponse:

```
{ "token": "<bearer session token>", "user": { "...": "serializeUser(user)" } }
```

Mobile men-deserialisasi memakai AuthResponse.serializer yang sudah ada, sehingga **tidak boleh ada field tambahan di level atas**.

A.4 Nonce - verifikasi anti-replay

Ini satu-satunya bagian yang berbeda dari alur Google dan paling sering salah diterapkan.

Mobile melakukan (auth_provider.dart:329-338):

1. membuat nonce acak, sebut raw;
2. mengirim SHA256(raw) ke Apple sebagai parameter nonce;
3. mengirim raw ke backend pada field nonce.

Apple menaruh nilai yang diterimanya - yaitu hash - ke dalam klaim nonce di identityToken.

Backend wajib membandingkan:

```
SHA256(body.nonce) === payload.nonce // hex lowercase
```

Menolak bila tidak sama. Membandingkan body.nonce langsung dengan payload.nonce **akan selalu gagal**, dan melewati pemeriksaan ini membuat identity token curian dapat diputar ulang.

A.5 Yang harus diverifikasi backend

Validasi identityToken:

- ambil kunci publik dari https://appleid.apple.com/auth/keys (JWKS, cache dan rotasi sesuai kid);
- iss harus https://appleid.apple.com;
- aud harus **bundle id aplikasi iOS** - bukan Services ID, karena ini alur native;
- exp belum lewat;
- klaim nonce cocok sesuai A.4.

Perilaku khas Apple yang berbeda dari Google:

Perilaku	Dampak
Nama hanya dikirim pada otorisasi pertama	Simpan givenName/familyName saat membuat akun. Pada login berikutnya field ini kosong - jangan menimpa nama yang sudah ada dengan nilai kosong .
Email bisa berupa relay privat @privaterelay.appleid.com	Perlakukan sebagai email sah. Jangan tolak, jangan normalisasi.
Email bisa tidak ada pada login berikutnya	Jangan pakai email sebagai kunci utama. Kunci utama adalah sub.

Perilaku	Dampak
email_verified bisa bertipe string "true" , bukan boolean	Bandingkan secara longgar.
sub stabil per Apple Developer Team	Cocok dipakai sebagai identitas permanen.

Skema database - butuh kolom baru yang mencerminkan google_id pada lib/db/src/schema/index.ts:151:

```
appleId: text("apple_id").unique(),
```

Resolusi akun - cermin dari resolveGoogleUser (artifacts/api-server/src/lib/google-account.ts):

1. cocokkan apple_id -> user tersebut;
2. jika tidak, cocokkan email terverifikasi:
 - belum tertaut Apple -> tautkan apple_id ini, kembalikan;
 - sudah tertaut id Apple lain -> 409;
3. jika tidak ada -> buat akun baru dengan default produk yang sama seperti jalur Google (passwordHash null, hasPassword: false).

authorizationCode - tidak diperlukan untuk login itu sendiri, tetapi dikirim mobile karena Apple mewajibkan aplikasi yang mendukung penghapusan akun untuk **mencabut token** melalui POST

<https://appleid.apple.com/auth/authorize>. Tukarkan kode ini di <https://appleid.apple.com/auth/token> lalu simpan refresh token bila fitur hapus akun akan mendukung akun Apple. Jika belum, abaikan field ini - jangan menolak request karenanya.

Rate limit - cermin googleNativeLoginLimiter

(artifacts/api-server/src/middleware/rate-limit.ts:120-127): per-IP, 20 permintaan per 15 menit, karena pemanggil belum terautentikasi.

Secret yang dibutuhkan: Apple Team ID, bundle id iOS (untuk aud), serta Key ID + private key .p8 - dua yang terakhir hanya bila authorizationCode akan ditukar.

A.6 Perilaku mobile saat backend belum siap

Mobile sudah menangani kondisi "endpoint belum ada" secara jujur, sehingga tidak ada klaim palsu bahwa login berhasil.

Status	Pesan ke pengguna (ID)
401	Apple tidak dapat memverifikasi proses masuk ini. Silakan coba lagi.
409	Email ini terhubung ke metode masuk lain. Masuklah dengan metode tersebut terlebih dahulu.
429	Terlalu banyak percobaan.
404, 501, 503	Sign in with Apple belum tersedia. Silakan coba lagi nanti.
Timeout/koneksi	Tidak ada koneksi.
Lainnya	Gagal masuk dengan Apple. Silakan coba lagi.
Dibatalkan pengguna	Tidak ada pesan - bukan kegagalan.

Selama endpoint belum ada, backend mengembalikan 404 dan pengguna melihat pesan "belum tersedia" - bukan error mentah.

A.7 Acceptance criteria

- POST /auth/apple/native tersedia dan tidak menuntut header Authorization.
- Signature, iss, aud, dan exp identityToken diverifikasi terhadap JWKS Apple.
- SHA256(body.nonce) dibandingkan dengan klaim nonce; ketidakcocokan menghasilkan 401.
- Kolom apple_id unik tersedia dan dipakai sebagai kunci utama pencocokan.
- Nama dari otorisasi pertama tersimpan dan tidak tertimpa nilai kosong pada login berikutnya.
- Email relay privat diterima sebagai email sah.
- Email yang sudah tertaut metode lain menghasilkan 409, bukan penggabungan diam-diam.
- Respons memakai skema AuthResponse yang sama dengan /auth/google/native.
- Rate limit per-IP terpasang.
- Endpoint terdaftar di lib/api-spec/openapi.yaml sehingga client Dart tergenerasi dapat menggantikan jembatan Dio mentah di auth_provider.dart:279-285.
- Log tidak memuat identityToken, authorizationCode, atau nonce mentah.
- Perangkat iOS fisik berhasil login, logout, lalu login ulang dengan akun Apple yang sama dan mendapat user yang sama.

A.8 Matriks uji minimum

Skenario	Ekspektasi
Otorisasi pertama, email asli	Akun baru dibuat, nama tersimpan.
Otorisasi pertama, "Sembunyikan email"	Akun dibuat dengan email relay.
Login kedua akun sama	User sama, nama tidak berubah jadi kosong.
Email sama sudah punya akun password	Akun tertaut, bukan duplikat.
Email sama sudah tertaut Apple id lain	409.
Nonce dimodifikasi	401.
identityToken kedaluwarsa	401.
aud milik aplikasi lain	401.
Token diputar ulang dari sesi lama	401 karena nonce tidak cocok.
Pengguna membatalkan sheet Apple	Tidak ada request, tidak ada pesan error.
Perangkat non-iOS	Tombol tidak dirender sama sekali.

A.9 Tanggung jawab

Pekerjaan	Mobile	Backend	Apple Admin
Capability Sign in with Apple di App ID	C	-	R
Entitlement pada target iOS	R	-	C
Pengambilan credential dan nonce	R	C	-
Endpoint /auth/apple/native	C	R	-
Verifikasi JWKS, aud, nonce	-	R	C
Kolom apple_id dan migrasi	-	R	-
Pencabutan token saat hapus akun	C	R	C

Pekerjaan	Mobile	Backend	Apple Admin
Entri OpenAPI dan regenerasi client	C	R	-
Uji perangkat iOS fisik	R	C	-

Keterangan: **R** = Responsible, **C** = Consulted.